

■■ BankSec Core v1.0

TECHNICAL ARCHITECTURE, OPERATIONAL GUIDE & SCOPE SPECIFICATION

1. Executive Summary & Value Proposition

BankSec Core is an enterprise-grade Application Security & Regulatory Assurance Engine built specifically for core banking systems, fintech web applications, payment gateways, and Open Banking APIs. It evaluates financial software against international banking benchmarks including **OAuth2 FAPI 1.0/2.0**, **PCI-DSS v4.0**, **OWASP ASVS Level 3**, and **PSD2 RTS (Strong Customer Authentication)**.

- **Financial-Grade Compliance:** Evaluates token binding (DPoP), anti-replay transaction locking, and strict header transport policies.
- **Executive & Auditor Visibility:** Translates technical probes into an interactive Audit Score (0-100%) and Grade (A+ to F).
- **Production Remediation:** Provides copy-pasteable remediation code in Express Node.js, Spring Boot Java, and Python.
- **Zero-Downtime Safe Probing:** Layer 7 non-destructive checks safe for live production banking endpoints.

2. Target Use Cases & Deployment Environments

- **Pre-Audit Readiness Assessment:** Prepare web applications for RBI, SEBI, ISO 27001, and PCI-DSS v4.0 audits.
- **DevSecOps Integration:** Validate security header configurations in CI/CD staging pipelines before release.
- **Third-Party Fintech API Vetting:** Verify security postures of vendors and Open Banking partners prior to integration.

3. System Architecture

BankSec Core utilizes a decoupled dual-deployment architecture supporting both **Standalone Local Execution (Node.js/Express)** and **Cloud Serverless Deployment (Streamlit Community Cloud)**.

Component	Technology Stack	Function & Responsibilities
Frontend UI Engine	HTML5, Vanilla CSS3, JS / Streamlit	Renders glassmorphism dashboard, metric dials, tabs, & modals.
Probe Engine	Node.js HTTP/S & Python Requests	Executes Layer 7 probes, TLS inspection, & header extraction.
Audit Engine	JavaScript & Python Rule Engine	Maps findings to controls, computes score (0-100%), & assigns Grade.
Data Model	banking-framework.js / Python dict	Defines 5 banking security domains, 11 controls, & OWASP matrices.

4. Scope Specification: What CAN & CANNOT Be Tested

Category	What CAN Be Tested (In-Scope)	What CANNOT Be Tested (Safety Boundary)
Transport Security	HTTPS / TLS 1.3 encryption & protocol enforcement.	Network Layer 3/4 DDoS or raw port scanning.
Security Headers	HSTS preloading, CSP, X-Frame-Options, X-Content-Type-Options.	Deep business logic flaws (account balance manipulation).
API & CORS Policy	Wildcard Access-Control-Allow-Origin (*) & Server Banner leakage.	Heavy SQL Injection / payload fuzzing (to avoid WAF bans).
Audit & Compliance	Automated mapping to 11 Banking Controls, OWASP, & FAPI.	Authenticated exploits requiring stored user credentials/MFA.

5. Audit Engine & Scoring Methodology

The Audit Engine evaluates financial application readiness using a transparent percentage formula:

Audit Compliance Score (%) = (Passed Controls / Total Controls) × 100

Score Range	Compliance Grade	Financial Audit Status & Recommended Action
90% – 100%	GRADE A+	Banking Compliant: Meets FAPI 1.0/2.0, PCI-DSS v4.0, & ASVS Level 3.
70% – 89%	GRADE B	Moderate Risk: Basic HTTPS active; secondary header fixes required before release.
0% – 69%	GRADE F	Critical Vulnerabilities: Essential banking controls missing. Unfit for production.

6. Core Banking Security Control Matrix (11 Controls)

Domain	ID	Control Name	Target Standard
Auth & Session	AUTH-01	Financial-Grade OAuth2 / FAPI DPoP Enforcer	FAPI 1.0 / ASVS V2.1 L3
Auth & Session	AUTH-02	PSD2 RTS Strong Customer Authentication (SCA)	PSD2 RTS / PCI 8.3
Auth & Session	AUTH-03	Anti-Clickjacking Frame Embedding Guard	ASVS V14.4 / PCI 6.4
Data Protection	DATA-01	Field-Level Payload Encryption (JWE/AES-256)	PCI-DSS v4.0 Req 3.4
Data Protection	DATA-02	Financial PII & PAN Data Masking Guard	PCI-DSS v4.0 Req 3.3
API Transport	API-01	Mandatory TLS 1.3 & Strict HSTS Preloading	ASVS V9.1 / FAPI 2.0
API Transport	API-02	API Gateway Rate-Limiting & Banner Removal	OWASP API Top 10 API4
Transaction	TXN-01	Anti-Replay HMAC Request Signing	FAPI 1.0 / OWASP API8
Transaction	TXN-02	Financial Idempotency Locking Engine	PSD2 Article 4
Audit & Compliance	LOG-01	Tamper-Proof Audit Logging & Non-Repudiation	PCI-DSS v4.0 Req 10.2
Audit & Compliance	LOG-02	Real-Time Fraud & Anomaly Detection Trigger	PCI-DSS v4.0 Req 10.6

7. Operational Quickstart Commands

Local Execution (Node.js):

```
cd D:\crazy_projects\banksec-suite  
node server.js  
# Access at http://localhost:8085
```

Streamlit Cloud Live URL:

```
https://banksec-core-4q43jtsstksw55gvvtzcm1.streamlit.app/
```